

Data leak risk assessment and least privilege analysis

1. Scenario

Conducted a security assessment following a data leakage incident at an educational technology company. The incident involved accidental exposure of confidential internal documents due to excessive user permissions and failure to apply the principle of least privilege.

2. Objective

Analyze the root cause of the data leak and recommend security controls aligned with NIST SP 800-53 AC-6 (Least Privilege) to reduce the risk of future incidents.

3. Activities performed

- Reviewed incident details and identified contributing factors leading to unauthorized data exposure.
- Analyzed access control weaknesses related to excessive permissions.
- Evaluated security controls using NIST Cybersecurity Framework (CSF).
- Reviewed NIST 800-53 AC-6 guidance for Least Privilege implementation.
- Developed recommendations to improve information privacy and access management.
- Justified proposed controls based on risk reduction and protection of sensitive information.

4. Key findings

- Internal folder permissions were not sufficiently restricted.
- Access rights exceeded business requirements.
- Sensitive information was shared unintentionally due to poor access governance.
- Lack of periodic privilege reviews increased exposure risk.

5. Recommendations

- implement role-based access control (RBAC)
- Restrict access to sensitive resources based on business need.
- Conduct regular access reviews and privilege audits.
- Automatically revoke temporary access permissions.
- Maintain audit logs of privileged user activity.

6. Frameworks and standards

- NIST Cybersecurity Framework (CSF)
- NIST SP-53 AC-6 (Least Privileged)
- Access control
- Information Privacy
- Risk assessment

7. Skills demonstrated

- risk analysis
- Incident analysis
- Access control review
- Data privacy assessment
- NIST Frameworks Application
- Security Recommendations
- Least Privilege Implementation